

Marco Integrativo GQM + PRAGMATIC para Indicadores Nacionales de Ciberseguridad

1. Introducción

Este marco integra el enfoque Goal-Question-Metric (GQM) con los criterios PRAGMATIC para evaluar y diseñar indicadores de ciberseguridad alineados con objetivos nacionales, siguiendo la filosofía de NIST SP 800-55 aplicada a un contexto país.

El objetivo es asegurar que cada métrica:

- Deriva de un objetivo de alto nivel claramente formulado (Goal).
- Responde a preguntas específicas de gestión o política pública (Question).
- Se operacionaliza en una o varias métricas bien definidas (Metric).
- Se evalúa sistemáticamente según los criterios PRAGMATIC: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable.

2. Objetivos nacionales de referencia (nivel G)

A modo ilustrativo, se definen cinco objetivos estratégicos nacionales de ciberseguridad:

G1. Reducir la frecuencia y severidad de los ciberincidentes significativos que afectan a servicios esenciales y operadores importantes.

G2. Incrementar la madurez y eficacia de los controles de ciberseguridad en organizaciones clave, en línea con NIST, ENS y NIS2.

G3. Mejorar la resiliencia operativa y la capacidad de recuperación ante ciberincidentes de alto impacto.

G4. Asegurar el cumplimiento efectivo de los marcos normativos (ENS, NIS2, RGPD y sectoriales), reduciendo el riesgo de sanciones, interrupciones y daños reputacionales.

G5. Optimizar la inversión pública y privada en ciberseguridad, maximizando el riesgo mitigado por euro invertido.

3. De objetivos a preguntas (nivel Q)

Cada objetivo se descompone en preguntas directrices que orientan la medición.

G1 → Preguntas clave

Q1.1. ¿Cuántos ciberincidentes significativos se producen anualmente en el conjunto de operadores esenciales e importantes?

Q1.2. ¿Cuáles son las principales tipologías de ataque y cómo evolucionan en el tiempo (ransomware, DDoS, compromisos de correo, etc.)?

Q1.3. ¿Cómo evolucionan el tiempo medio de detección (MTTD) y el tiempo medio de respuesta (MTTR) ante incidentes significativos?

Q1.4. ¿Qué sectores y tipos de servicios muestran mayor concentración de incidentes graves?

G2 → Preguntas clave

Q2.1. ¿En qué medida los operadores esenciales e importantes han implantado controles técnicos y organizativos clave (MFA, gestión de vulnerabilidades, segmentación, monitorización continua)?

Q2.2. ¿Cómo evoluciona la madurez de los programas de ciberseguridad y de medición (tipo NIST SP 800-55) en las organizaciones clave?

Q2.3. ¿Qué brechas se observan entre los niveles de control declarados y la realidad reflejada por incidentes y auditorías?

G3 → Preguntas clave

Q3.1. ¿En qué medida las organizaciones críticas cumplen sus RTO/RPO en incidentes cibernéticos significativos?

Q3.2. ¿Con qué frecuencia se realizan ejercicios de crisis cibernética y qué porcentaje de lecciones aprendidas se implementa efectivamente?

Q3.3. ¿Cuál es el tiempo medio de restablecimiento de servicios esenciales tras un ciberataque grave?

G4 → Preguntas clave

Q4.1. ¿Cuál es el nivel de cumplimiento medio de ENS/NIS2/RGPD entre organizaciones sujetas?

Q4.2. ¿Qué tipos de incumplimientos son más frecuentes y qué impacto tienen (sanciones, restricciones, obligaciones de remediación)?

Q4.3. ¿Cómo evoluciona el número de auditorías, acciones de supervisión y medidas correctoras a lo largo del tiempo?

G5 → Preguntas clave

Q5.1. ¿Qué porcentaje del presupuesto de TI se destina a ciberseguridad en los distintos sectores estratégicos?

Q5.2. ¿Cómo se relacionan los niveles de inversión con los niveles de incidentes, madurez y cumplimiento?

Q5.3. ¿Existen estimaciones sistemáticas de pérdidas evitadas o riesgo mitigado asociado a programas de ciberseguridad?

4. De preguntas a métricas (nivel M)

A continuación se presenta un conjunto base de métricas nacionales, cada una vinculada a objetivos (G) y preguntas (Q).

- M1. Número anual de ciberincidentes significativos notificados por operadores esenciales e importantes.
- M2. Tasa de incidencia (incidentes significativos por 100 organizaciones reguladas) por sector.
- M3. Distribución porcentual de incidentes por tipología de ataque.
- M4. Tiempo medio de detección (MTTD) de incidentes significativos.
- M5. Tiempo medio de respuesta (MTTR) de incidentes significativos.
- M6. Tiempo medio de recuperación de servicios críticos tras incidentes significativos.
- M7. Índice de implantación de controles clave (porcentaje de organizaciones con MFA generalizado, gestión de vulnerabilidades madura, segmentación efectiva, monitorización 24/7, etc.).
- M8. Índice de madurez de ciberseguridad (IGM) medio por sector.
- M9. Porcentaje de procesos críticos con RTO/RPO cumplidos en incidentes cibernéticos.
- M10. Número de ejercicios de crisis cibernética realizados al año por organización, y porcentaje medio de lecciones aprendidas implementadas.
- M11. Nivel medio de cumplimiento ENS/NIS2 (por ejemplo, porcentaje de controles cumplidos por dominio).
- M12. Número de sanciones y medidas correctoras relacionadas con ciberseguridad al año, por sector.
- M13. Porcentaje medio del presupuesto de TI dedicado a ciberseguridad.
- M14. Relación entre inversión en ciberseguridad e indicadores de resultado (incidentes, tiempos de respuesta, cumplimiento, etc.).
- M15. Estimación de pérdidas económicas evitadas (o riesgo mitigado) atribuible a programas de ciberseguridad.

En los documentos complementarios se detalla la evaluación PRAGMATIC de cada métrica y su posible implementación en encuestas, sistemas de reporte y cuadros de mando.